AA-ZTCE tightened core: internal red-team and formal report

Proposal originator: Abid Yousef. Audit candidate 0.2. Dynamic execution: 2026-10-15T05:59:06.448240+00:00.

Decision and status

The local runtime has been tightened after five reproduced gaps. Original behavior is preserved where valid; the original 61 tests pass. The new dynamic campaign and 20 solver queries passed their stated assertions/expected outcomes. This is an internally tested reference implementation, not a production-certified or independently validated system. No external auditor has received or reviewed the package.

Reproduced findings and corrections

Finding	Before	Corrected behavior
F01: task-purpose drift	An existing grant released data after its authoritative task purpose changed.	Grants bind the approved task snapshot, including purpose, scope, participants and version. A change requires fresh admission.
F02: identity rebind	A replacement instance registered under the same name could use an old session to trigger an encrypted release.	Grants pin enrollment generation, signing/exchange keys, clearance and compartments; old grants are rejected.
F03: identity-update race	Registration committed while a request held the release lock; that paused request later released using stale identity evidence.	Registration, task configuration and supported lifecycle updates serialize with protected release.
F04: malformed input	A malformed envelope raised an unhandled AttributeError.	Bounded strict schemas and finite-time checks return controlled denials.
F05: pending-challenge pressure	300 requests were accepted and stored for one agent.	Per-agent capacity 16, global capacity 128 and expired-entry reclamation. Session/request/event memory bounds were added.

F02 demonstrates wrong-instance grant reuse at the release boundary; it does not show that the replacement could decrypt ciphertext intended for the original instance. F05 bounds state, not all denial-of-service behavior. Fairness and durable rate limiting remain integration work.

The deterministic F03 probe pauses an actual signed request after signature verification, starts an identity update, and observes ordering. Previously the update completed with release_count=0 and the old request then released. With the correction, update commit waits for that already-authorized release; release_count=1 at commit. Future old-grant operations are denied. This is a defined local linearization boundary, not retroactive cancellation.

Executed dynamic and regression results

- Original tests: 61/61 passed, including the three original limitation demonstrations.
- Stateful campaign: 200 seeded episodes, 5,000 actions; 166 successful reads and 738 denied reads.
- Dynamic assertions: 2159/2159 passed. These include multiple checks per event and are not distinct-attack counts.

- Malformed-input variants: 57 controlled denials, including wrong types, oversized fields and nonfinite/oversized timestamps.

- Thread schedules: 120 trials across identity, task, policy, revoke, environment and group updates, each with three request workers. No accepted old-grant operation started after a committed update.

- Attack-associated tool-action simulations: 14 out-of-scope actions denied; one benign and one maliciously motivated in-scope read allowed.

Scripts, logs and machine-readable before/after traces are included. Untrusted prompt/context texts are associated with scripted tool calls; no independent live LLM consumes them. This tests enforcement after malicious action selection, not cognitive prompt-injection susceptibility.

Z3 results and mathematical scope

Solver: Z3 5.3.0. Twenty queries returned expected outcomes: 14 UNSAT safety checks, two SAT legitimate-operation witnesses and four SAT counterexamples to intentionally weakened designs.

The base and inductive checks establish revocation invariance for arbitrary finite traces of the specified single-session abstraction. Added predicates require identity/task binding and current epoch equality. Integer quota checks establish bounds under serialized admission. The rights-intersection theorem describes a proposed delegation rule, not a full implementation of subdelegation chains.

These results assume truthful evidence, cryptographic validity and atomic current-state enforcement. They do not prove Python source refinement, primitive security, sandbox isolation, distributed atomicity or LLM behavior. The SMT inputs and witnesses are included so an independent reviewer can challenge both assumptions and model omissions.

Remaining limits

Binding the task snapshot closes a workflow-authority gap; it cannot extract hidden goals. A harmful read inside approved scope still succeeds. Previously received plaintext remains available after revocation. False trusted-verifier evidence can still cause admission. These limits remain explicit.

The control-plane registries are trusted in-process harness state. Production must prevent direct mutation and require authenticated serialized administration. A single process lock does not solve cross-host cache races, queue cancellation, clock trust or transactions with external services. General-purpose isolated agent tools, integrated VM/container deployment, real model benchmarks, covert channels, durable audit storage and higher-layer disruption efficacy remain unverified or unimplemented.

Events use bounded memory; a deployment needs an external tamper-evident audit sink rather than relying on the retained deque. Quotas preserve bounded state but do not establish fair admission under hostile load. This remains a reference harness, not production-ready security infrastructure.

External audit handoff

AUDIT_SCOPE.md prioritizes token lifecycle, crypto validation, policy boundaries, identity rotation, task-binding freshness, atomic update ordering and source-to-model correspondence. The source and evidence manifest freezes the delivered candidate. The original engine is retained only for reproducing old findings and is clearly separated under before/.

No audit has been scheduled, sent, purchased or independently completed. A verified auditor/contact is required to transmit the package; engagement terms, budget and dates are required to book paid work. No new authorization is needed merely to continue internal testing already requested.

Reproduce

Run bash run.sh. It installs missing dependencies locally and executes regression, finding reproduction, stateful/thread, Z3 and scripted attack checks. Reruns regenerate results; their hashes differ from the delivered original snapshot. Use root engine.py for the corrected implementation and before/engine.py only for reproductions.